

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA5112

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 20

TOTAL MARKS: 20

Annexure A MOCK INTERVIEW

Code of Conduct:

*I G. Srivalli (192365014) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:

G. Srivalli

Annexure A

MOCK INTERVIEW

1. Which would you prioritize in a secure network design: **performance or security**, and how would you balance both?
2. Can you explain the difference between **stateful and stateless firewalls**, and which one is more suitable for enterprise networks?
3. If an IDS generates too many false positives, how would you optimize its performance?
4. How would you design a **real-time intrusion detection system** for high-speed networks?
5. What are the key challenges in detecting **zero-day malware**, and how would you address them?
6. How would you differentiate between **signature-based and anomaly-based IDS**, and when would you use each?
7. If a network is under a **DDoS attack**, what immediate and long-term mitigation strategies would you apply?
8. How would you secure **remote access** to an enterprise network?
9. What are the limitations of **traditional antivirus software**, and how can modern solutions overcome them?
10. How would you design a **secure email filtering system** to prevent phishing and spam attacks?
11. If an attacker bypasses firewall rules, what additional layers of security would you implement?
12. How would you evaluate the effectiveness of **network segmentation** in preventing cyberattacks?
13. What role does **encryption** play in preventing malware attacks, if any?
14. How would you secure a **cloud-based network infrastructure**?
15. What is the importance of **log analysis and monitoring** in network security?
16. How would you respond to a **security breach in a corporate network**?
17. What are the advantages and limitations of **next-generation firewalls (NGFW)**?
18. How would you integrate **IDS/IPS with SIEM systems** for better threat detection?
19. What are the best practices for **patch management and vulnerability assessment**?
20. How would you design a **future-proof network security architecture** considering emerging threats?

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Technical Knowledge	25	Demonstrates strong and accurate subject knowledge with in-depth understanding	Shows good knowledge with minor gaps	Basic knowledge with noticeable errors	Lacks fundamental technical knowledge
Problem Solving	25	Solves problems logically and applies concepts effectively in real scenarios	Applies concepts with moderate accuracy	Limited problem-solving ability; requires guidance	Unable to solve or apply concepts
Analytical Thinking	15	Analyzes questions critically and provides well-structured, logical answers	Provides reasonable analysis with some structure	Superficial or partially structured responses	No analytical thinking demonstrated
Communication	15	Communicates clearly, confidently, and professionally with proper terminology	Communicates well with minor hesitation	Communication lacks clarity or confidence	Unable to communicate effectively
Confidence	15	Displays high confidence, positive attitude, and professional behavior throughout	Shows good confidence with minor issues	Low confidence; inconsistent behavior	Lacks confidence and professionalism

1. Which would you prioritize in a secure network design: performance or security, and how would you balance both?

I would balance both rather than choosing one over the other, because heavy security without performance stops business operations, while fast performance without security exposes the business to attacks. In practice, I balance them by using hardware acceleration like SmartNICs or ASICs for SSL decryption, placing heavy inspection like IPS at high-risk perimeters while using lighter stateful rules on trusted internal VLANs, and optimizing firewall rule order so high-traffic rules are evaluated first.

2. Can you explain the difference between stateful and stateless firewalls, and which one is more suitable for enterprise networks?

Stateless firewalls look at individual packets in isolation using static rules like IP address and port numbers, which makes them fast but unaware of connection context. Stateful firewalls keep track of active session states in a table, allowing return traffic for legitimate outgoing requests automatically. For an enterprise network, stateful firewalls—or Next-Gen Firewalls—are essential because they protect against dynamic attacks, IP spoofing, and session hijacking.

3. If an IDS generates too many false positives, how would you optimize its performance?

To fix false positive overload, I would first disable unnecessary default rules that don't apply to our environment, like IIS rules on a Linux system. Then, I'd re-baseline anomaly engines during normal operational cycles like backups, add explicit whitelists for trusted internal vulnerability scanners, and integrate the IDS with a SIEM to aggregate duplicate alerts and enrich them with context.

4. How would you design a real-time intrusion detection system for high-speed networks?

For high-speed, multi-gigabit traffic, I'd use network packet brokers to load balance flows across multiple sensor nodes using 5-tuple hashing. On the software side, I'd implement kernel-bypass technologies like DPDK or PF_RING to pass packets directly into user-space RAM, and set up a multi-tiered inspection pipeline where light signature filters drop benign traffic immediately before deeper inspection takes over.

5. What are the key challenges in detecting zero-day malware, and how would you address them?

The biggest challenge is that zero-day threats have no existing signature or file hash, and they often use obfuscation or encrypted C2 channels. I would address this by using Endpoint Detection and Response tools that track runtime behaviors like memory injection, detonating unknown files in automated sandboxes before delivery, using machine learning heuristics, and enabling outbound TLS decryption to inspect encrypted traffic.

6. How would you differentiate between signature-based and anomaly-based IDS, and when would you use each?

Signature-based IDS matches traffic against known threat patterns; it's very accurate with low false positives, but completely misses zero-days. Anomaly-based IDS establishes a baseline of normal behavior and flags deviations, making it great for zero-days but prone to false alarms. I'd use signature-based IDS at the outer perimeter for quick, low-overhead filtering, and anomaly-based IDS inside sensitive core networks to catch advanced persistent threats.

7. If a network is under a DDoS attack, what immediate and long-term mitigation strategies would you apply?

Immediately, I would identify the attack type, shift traffic to cloud scrubbing services like Cloudflare or AWS Shield, enable WAF rate-limiting or CAPTCHAs for layer-7 floods, and use BGP blackholing as a last resort. Long-term, I'd implement Anycast routing across multiple data centers, auto-scaling infrastructure, and maintain dedicated anti-DDoS service provider SLAs.

8. How would you secure remote access to an enterprise network?

I would implement a Zero Trust Network Access architecture. This means requiring phishing-resistant multi-factor authentication, verifying endpoint health and patch posture before granting access, enforcing strict least-privilege policies to specific applications instead of full network access, and wrapping all traffic in strong TLS 1.3 or IPsec encryption.

9. What are the limitations of traditional antivirus software, and how can modern solutions overcome them?

Traditional antivirus relies heavily on static file signatures, making it completely blind to zero-days, fileless attacks, and memory-only malware. Modern EDR and XDR solutions overcome this by monitoring dynamic behavioral activity, using machine learning to detect suspicious code structures, and providing automated response capabilities like host isolation and process termination.

10. How would you design a secure email filtering system to prevent phishing and spam attacks?

I'd build a multi-layered system starting with domain authentication—enforcing SPF, DKIM, and DMARC reject policies. Then, I'd route inbound traffic through a Secure Email Gateway with dynamic link rewriting for time-of-click analysis, attachment sandboxing, and natural language processing to flag executive impersonation attempts.

11. If an attacker bypasses firewall rules, what additional layers of security would you implement?

I'd rely on a defense-in-depth model. That includes microsegmenting internal networks to block lateral movement, running host-based EDR to stop malicious execution, enforcing strict identity controls via Privileged Access Management, deploying internal honeypots to catch lateral probes early, and enforcing strict Data Loss Prevention policies.

12. How would you evaluate the effectiveness of network segmentation in preventing cyberattacks?

I would conduct internal breach and attack simulations and manual penetration tests to verify if a compromised host in one segment can reach restricted zones. I'd also audit firewall rules for overly broad permissions, monitor NetFlow logs to verify traffic stays within defined inter-segment boundaries, and measure the reduction of simulated malware blast radiuses.

13. What role does encryption play in preventing malware attacks, if any?

Encryption protects against malware distribution by securing firmware updates and code signatures, which stops supply chain and Man-in-the-Middle injection attacks. It

also prevents malware from reading stolen sensitive data. However, since attackers also hide malware traffic inside SSL/TLS encryption, we must pair encryption with outbound TLS decryption proxies to inspect payloads.

14. How would you secure a cloud-based network infrastructure?

I start by understanding the Shared Responsibility Model, enforcing strong Role-Based Access Control via IAM with zero hardcoded API keys, and isolating workloads inside Virtual Private Clouds with tight NACLs and Security Groups. Additionally, I'd deploy Cloud Security Posture Management to continuously detect misconfigurations and keep all data encrypted at rest and in transit.

15. What is the importance of log analysis and monitoring in network security?

Log analysis gives us visibility across the entire network. Correlating logs from firewalls, endpoints, and identity providers helps us detect early indicators of compromise like lateral movement or brute-force attacks. It's vital for incident forensics, mandatory for regulatory compliance, and feeds into SIEM platforms to speed up threat detection and response times.

16. How would you respond to a security breach in a corporate network?

I follow the NIST Incident Response lifecycle. I'd identify and scope the breach, contain it immediately by isolating infected hosts and revoking compromised credentials, eradicate the threat by removing malware and patching vulnerabilities, recover by restoring verified clean systems from backups with heightened monitoring, and finally conduct a post-incident review to strengthen our defense.

17. What are the advantages and limitations of next-generation firewalls (NGFW)?

The main advantages of an NGFW are Deep Packet Inspection, application awareness, user identity integration, and combining firewalling, IPS, and anti-malware into one engine. The key limitations are performance degradation when running heavy SSL decryption and high hardware and licensing costs compared to traditional firewalls.

18. How would you integrate IDS/IPS with SIEM systems for better threat detection?

I'd configure the IDS/IPS to forward normalized logs via Syslog or CEF to the SIEM.

The SIEM correlates these IDS alerts with other log sources—like web server or database logs—to reduce noise, enriches the alerts with threat intelligence feeds, and uses SOAR playbooks to automatically execute block actions on the firewall when high-confidence alerts trigger.

19. What are the best practices for patch management and vulnerability assessment?

For vulnerability management, perform continuous asset discovery and credentialed scans, prioritizing vulnerabilities based on real-world exploitability and business risk rather than raw CVSS scores. For patch management, systematically test patches in non-production environments before deployment, automate routine updates, and maintain an emergency patch workflow for zero-days actively being exploited.

20. How would you design a future-proof network security architecture considering emerging threats?

I would base it on Zero Trust principles—never trust, always verify. I'd adopt a Cloud-Native SASE framework to unify network and security functions at the edge, prepare for post-quantum cryptography standards to secure long-term data, utilize AI and machine learning for behavioral telemetry, and ensure all security tools offer open APIs for automated response.